Consolidated Pentest Report

MONGOLZ Security

Multi-authority masking + reveal intelligent network camera and integrated control server

System under test

https://mongolz.vercel.app

Period

2026-05-15 → 2026-05-17

Methodology

SAST · DAST · secret scanning · multi-agent manual audit

Version

1.0 · Capstone 3B-26-1 (2026-01-CD-03-07)

This document is auto-generated weekly by the GitHub Actions security workflow. It supersedes any previous revision and is the canonical pentest record for the capstone defense.

Table of contents

Executive Summary 3

1. Scope 3

2. Methodology 3

3. SAST findings (Semgrep) 4

3.1 gcm-no-tag-length — explicit GCM auth tag length 4

3.2 missing-user — Dockerfile runs as root 4

4. Nuclei DAST findings 4

5. OWASP ZAP DAST findings 5

5.1 Triaged ZAP warnings 5

6. Secret scanning + dependency audit 7

7. Manual + agent audit (verified bugs fixed) 7

Triaged as false positive (not exploitable) 8

8. Residual risks (accepted) 8

9. Continuous controls summary 9

10. Document control 9

Executive Summary

Layer	Tool	Findings	Status
SAST (static code analysis)	Semgrep — 681 rules across OWASP, TS, React, Next.js, Python	**2**	All fixed (b0973b0)
Secret scanning	trufflehog `--only-verified`	**0**	Clean
Dependency audit	`npm audit --omit=dev` + `pip-audit`	**0** critical	Clean
DAST (dynamic)	Nuclei — 8000+ CVE / misconfig templates	**0**	Clean
DAST (dynamic)	OWASP ZAP baseline (passive + AJAX spider)	_see §5_	_see §5_
Manual + AI audit	3 parallel review agents (auth, API, i18n)	**27**	11 verified bugs fixed, 16 false-positive / accepted
Total verified bugs found and fixed		**13**	■

Top-level conclusion: No exploitable critical or high vulnerabilities remain in the production deployment as of 2026-05-17.

1. Scope

In scope:

- Web application: `https://mongolz.vercel.app/*`
- API surface: every `/api/*` route in the Next.js application
- ML service: `https://mongolz-ml-production.up.railway.app/*`
- Source code in the `khajybyek/mongolz-next` repository

Out of scope:

- Supabase platform internals (vendor responsibility)
- Vercel and Railway platform internals
- Third-party packages (covered by upstream advisories)

2. Methodology

The capstone substituted formal external pentest with a layered **continuous security testing** approach:

1. **Static (SAST)** — every push runs Semgrep with `p/owasp-top-ten`, `p/security-audit`, `p/typescript`, `p/react`, `p/nextjs`, `p/python`. ERROR-severity findings block the build.
2. **Secret scanning** — every PR and weekly schedule runs trufflehog with `--only-verified` (catches actually-active leaked credentials, not just pattern hits).
3. **Dependency audit** — `npm audit --omit=dev` + `pip-audit` on every push and weekly.
4. **Dynamic (DAST)** — weekly + on-demand:

- **Nuclei** with templates `cves,vulnerabilities,misconfiguration,exposures`, rate-limited to 50 RPS.
- **OWASP ZAP baseline** with `-a` (alpha passive rules) + `-j` (AJAX spider for JS-heavy SPA routes).

5. **Manual + agent audit** — three parallel review agents inspected: (a) auth + TOTP + step-up + secrets, (b) every API route + Server Action, (c) i18n completeness + UI bugs. Findings triaged against actual code before fix or accept.

All scanners run from GitHub-hosted runners against the **production** deployment.

3. SAST findings (Semgrep)

Two ERROR-severity findings detected on the first run. Both fixed in commit `b0973b0`.

3.1 `gcm-no-tag-length` — explicit GCM auth tag length

- **Location:** `lib/camera-crypto.ts` — RTSP / HTTP camera URL encryption
- **Risk:** Without an explicit `authTagLength` option, Node's GCM cipher uses an implementation-default tag size. If a future Node release changes the default, ciphertext authenticity could be silently downgraded.
- **Fix:** Pass `{ authTagLength: 16 }` to both `createCipheriv` and `createDecipheriv`. Tag size is now locked at 128 bits per NIST SP 800-38D.

3.2 `missing-user` — Dockerfile runs as root

- **Location:** `ml-service/Dockerfile`
- **Risk:** Remote code execution in the FastAPI process could escalate to write `/etc`, mount filesystems, or escape the container.
- **Fix:** Add `useradd --uid 10001 mongolz`, `chown` the pip user-site directory, run with `USER mongolz`. Container now operates as an unprivileged user.

Subsequent runs (af68c29, b0973b0, 9fad799, 64631b1): 0 findings.

4. Nuclei DAST findings

```
Target: https://mongolz.vercel.app
Templates: cves, vulnerabilities, misconfiguration, exposures
Severity filter: critical, high, medium
Rate limit: 50 RPS
Report date: 2026-05-17
Findings: 0
```

No CVEs, misconfigurations, or exposed admin panels detected.

5. OWASP ZAP DAST findings

```
Target: https://mongolz.vercel.app
Mode: baseline (passive rules + AJAX spider)
Run: 25987614600 (workflow_dispatch, 2026-05-17)
PASS: 52 rules
WARN-NEW: 18 informational/medium
FAIL-NEW: 0
```

5.1 Triaged ZAP warnings

ZAP rule	Hits	Status	Notes
10010 Cookie No HttpOnly Flag	1	**Accepted**	`mongolz-lang` (language preference) must be readable by the client to switch UI locale. No session data.
10011 Cookie Without Secure Flag	1	**Accepted**	Same `mongolz-lang` cookie. `Secure` is set in production; ZAP scanned a redirect path before TLS upgrade.
10015 Re-examine Cache-control Directives	1	**Accepted**	Static assets cached as designed.
10021 X-Content-Type-Options Header Missing	1	**False positive**	Verified `x-content-type-options: nosniff` is set in production (proxy.ts + next.config.ts headers). ZAP hit a path that bypasses the middleware (likely `/_next/static/*`).
10031 User Controllable HTML Element Attribute (XSS)	2	**Accepted**	Search input echoed via React JSX which auto-escapes. No `dangerouslySetInnerHTML` in source.
10035 Strict-Transport-Security Header Not Set	1	**False positive**	Verified `strict-transport-security` is set in production. Same cause as 10021.
10037 Server Leaks Information via X-Powered-By	5	**Fixed in 9fad799**	Set `poweredByHeader: false` in `next.config.ts`. Pending re-scan to confirm.

ZAP rule	Hits	Status	Notes
10049 Non-Storable Content	10	**Accepted**	Server-rendered SSR pages MUST NOT be stored by intermediaries (privacy-by-design).
10050 Retrieved from Cache	5	**Accepted**	Static assets retrieved from Vercel CDN.
10055 CSP: Wildcard Directive	12	**Accepted**	`img-src` allows http: only for LAN IP-webcam streams (media data, no token leak). `connect-src` is HTTPS-only. Documented residual risk.
10063 Permissions Policy Header Not Set	1	**False positive**	Verified `permissions-policy: camera=(self), microphone=(), …` is set. Same root cause as 10021.
10094 Base64 Disclosure	5	**Accepted**	ONNX WebGPU model embeddings displayed as base64 in face-detection demo.
10098 Cross-Domain Misconfiguration	5	**Accepted**	Supabase realtime requires `Access-Control-Allow-Origin: *` on its endpoints; we don't control Supabase headers.
10109 Modern Web Application	5	**Informational**	ZAP detected SPA navigation. No issue.
10111 Authentication Request Identified	2	**Informational**	Login endpoints detected; not a vulnerability.
10202 Absence of Anti-CSRF Tokens	4	**Accepted**	Replaced by `SameSite=Strict` on the pre-TOTP cookie and `Lax` on the session cookie. Server Actions also include their own protection.
90004 Cross-Origin-Embedder-Policy Missing	6	**Accepted**	Adding COEP would break Supabase Realtime WebSocket which loads cross-origin (Supabase) WASM.
90005 Sec-Fetch-Dest Header Missing	12	**Informational**	Browser sends this automatically on modern browsers; ZAP probes a synthetic client.

Net result: 0 FAIL, 1 real fix (X-Powered-By suppression in commit pending), 17 accepted with documented rationale, 3 false positives (verified the headers are set in production via direct `curl -I`).

6. Secret scanning + dependency audit

- **trufflehog:** scanned full repo history. Verified-only mode = 0 findings. Pattern-only mode rejected.
- **npm audit:** 0 critical, 0 high. Production dependencies tracked.
- **pip-audit (ml-service):** 0 high. CVE feed up to date.

7. Manual + agent audit (verified bugs fixed)

Out of 27 raised findings, 11 verified as real and fixed; 16 triaged as false positive or accepted intentional behavior.

#	Severity	Issue	Fix commit
1	HIGH	Backup endpoint exfiltrated audit_log without step-up TOTP	b2c53fc
2	HIGH	`addSuspectAction` lacked fresh reauth (planting bias risk)	292b3e7
3	HIGH	`createRule` + `toggleRule` lacked fresh reauth	292b3e7
4	HIGH	Webhook URL allowed SSRF to private IPs	292b3e7
5	HIGH	TOTP code replay within 30-second validity window	af68c29
6	HIGH	Webhook DNS rebinding (TOCTOU)	af68c29
7	MEDIUM	Pre-TOTP cookie sameSite `lax` → `strict`	292b3e7
8	MEDIUM	`/api/recording/upload` fail-open if `ML_SERVICE_TOKEN` missing	292b3e7

#	Severity	Issue	Fix commit
9	MEDIUM	`deleteUserAction` last-admin race — added post-delete audit	292b3e7
10	MEDIUM	CSP `connect-src http:` (exfiltration channel)	b2c53fc
11	MEDIUM	`/api/uptime` exposed exact latency timings	b2c53fc
12	LOW	HSTS / nosniff / Referrer-Policy / Permissions-Policy missing	b2c53fc
13	LOW	`session-pin.ts` HMAC fallback string `"fallback"` removed	292b3e7

(rows above are inclusive of the SAST fixes from §3)

Triaged as false positive (not exploitable)

- `/api/admin/backup` 50K limit — defensive bound, admin-gated
- `/api/gdpr/export` `.or()` filter — Supabase PostgREST is structured, not SQL-injectable
- `sanitizeNextPath` double-encoded slashes — `decodeURIComponent` decodes one level, so `%252F` stays `%2F` and fails `startsWith("/")`
- `/api/alerts/[id]/label` admin check — `requireAdminApi()` is on line 14
- TOTP recovery codes returned in HTTP response — intentional one-time setup, hashes only in DB

8. Residual risks (accepted)

#	Risk	Mitigation in place	Why accepted
1	Service-role key compromise	rotation procedure (RUNBOOK §4) + Vercel env encryption	Architectural split (Vault) is out of capstone scope
2	No formal external pentest	continuous SAST + DAST + agent audit	Replaced for capstone; external annual pentest recommended pre-production

#	Risk	Mitigation in place	Why accepted
3	Leaked password protection disabled	rate limit + strong-password policy	Supabase Pro plan feature
4	HTTP IP-webcam allowed via `img-src http:`	private-LAN only, no token leak risk	Required for the gar utas webcam UX
5	Pre-TOTP cookie not single-use across tabs	sameSite `strict` + 2-min TTL + HMAC signature	Cookie is short-lived and signed; attack window is microscopic

9. Continuous controls summary

Control	Frequency	Outcome 2026-05-17
Semgrep SAST	every push	0 findings
trufflehog	every PR + weekly	0 findings
Nuclei DAST	weekly + on-demand	0 findings
OWASP ZAP DAST	weekly + on-demand	_pending in §5_
npm audit	every push + weekly	0 critical
pip-audit	every push + weekly	0 high
Multi-agent review	per major change	11 verified bugs fixed
Backup restore drill	quarterly	procedure documented (RUNBOOK §3)
Key rotation reminder	weekly	cron emits `KEY_ROTATION_DUE` audit row

10. Document control

- **Version:** 1.0
- **Generated:** 2026-05-17
- **Owner:** MONGOLZ Security — capstone 3B-26-1 (2026-01-CD-03-07)
- **Next regeneration:** triggered by the weekly Monday 06:00 UTC security run, or on-demand via GitHub Actions
- **Contact:** security@mongolz.local (see `/.well-known/security.txt`)